

## Test Tema 47 #1

Actualizado el 18/03/2026

### 1. Se entiende por integridad de la información:

- a) Propiedad o característica consistente en que el activo no ha sido alterado de manera no autorizada.
- b) Que cada persona accederá únicamente a la que le corresponda.
- c) Disposición de los servicios a ser usados cuando sea necesario.
- d) Característica que previene contra la denegación no autorizada de acceso a activos del dominio.

### 2. Respecto al análisis y gestión de riesgos:

- a) En la gestión de riesgos, ningún riesgo identificado puede declararse como asumible ya que la metodología trata de evitar cualquier daño en nuestra organización
- b) Si tenemos implementadas salvaguardas en nuestro sistema, no tiene sentido disponer de planes de continuidad pues las amenazas no llegarán a materializarse
- c) Un led que indique el mal funcionamiento de un disco de un RAID puede considerarse como una salvaguarda
- d) Cualquier amenaza afecta a todas las dimensiones de un activo

### 3. El término MAGERIT es un acrónimo que procede de los siguientes términos, o significa lo siguiente:

- a) Mercado Abierto y Gratuito a la Exportación de Recursos Informáticos y de Telecomunicaciones
- b) Sistema Informático propio, financiado y desarrollado por la Comunidad Autónoma de Madrid (de aquí el nombre de: «MAGERIT»)
- c) Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información
- d) Method Aid for Gradual Employ Resource of Information Technology

### 4. Señale cuál de las siguientes normas se debe tener en cuenta en el Área de Seguridad de una organización:

- a) ISO 19799.
- b) ISO 14508 sobre perfiles de protección.
- c) ISO 14848.
- d) ISO 27002.

### 5. Se entiende por integridad de la información, según la norma ISO 27002:

- a) Que cada persona accederá únicamente a la información que le corresponda.
- b) Disposición de los servicios a ser usados cuando sea necesario.
- c) Característica que previene contra la denegación no autorizada de acceso a activos del dominio.
- d) La salvaguarda de la precisión y completitud de la información y sus métodos de proceso.

### 6. Si el equipo del proyecto decide que hay que seleccionar un proveedor más estable para el proyecto, ¿qué estrategia de respuesta a los riesgos está utilizando?

- a) Evitar el riesgo.
- b) Mitigar el riesgo.
- c) Transferir el riesgo.
- d) Aceptar el riesgo.

### 7. Respecto a la metodología MAGERIT y la gestión de riesgos, el riesgo calculado tomando en consideración el valor propio de un activo y el valor de los activos que depende de él se denomina:

- a) Riesgo inherente
- b) Riesgo repercutido
- c) Riesgo acumulado
- d) Riesgo total

**8. Según la Metodología de Análisis y Gestión de Riesgos (MAGERIT) indicar a qué concepto corresponde la siguiente definición «toda debilidad que puede ser aprovechada por una amenaza, o más detalladamente a las debilidades de los activos o de sus medidas de protección que facilitan el éxito de una amenaza potencial»:**

- a) Salvaguarda
- b) Riesgo
- c) Impacto
- d) Vulnerabilidad

**9. Indique la opción correcta, de entre las siguientes, respecto al objetivo de la metodología MAGERIT:**

- a) La eliminación completa de los riesgos físicos a los que se exponen los activos de una organización.
- b) Facilitar información sobre incidentes de ciberseguridad.
- c) Proporcionar una guía para analizar y gestionar el riesgo de sistemas TIC.
- d) Reducir el número de activos para reducir la exposición de la organización a ciberataques.

**10. En relación con la versión 3 de MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información), podemos afirmar que:**

- a) Es una actualización realizada por el CCN (Centro Criptológico Nacional), con el fin de adaptar la versión anterior a los requerimientos exigidos en el Esquema Nacional de Seguridad.
- b) Fue elaborada por el antiguo Consejo Superior de Administración Electrónica, pero ha dejado de tener validez dado que no se adapta a los requerimientos exigidos en el Esquema Nacional de Seguridad.
- c) El CCN ha desarrollado una herramienta denominada PILAR que implementa la metodología MAGERIT
- d) -

**11. En relación con la seguridad de los sistemas de información, seleccione la respuesta correcta:**

- a) Amenaza es la debilidad de un sistema de información que puede ser explotada mediante un ataque.
- b) Impacto es la probabilidad de que se produzca un daño en la organización.
- c) Mecanismos de Seguridad son las acciones llevadas a cabo encaminadas a reducir el riesgo sobre alguna vulnerabilidad.
- d) Vulnerabilidad es un evento que pueden desencadenar un incidente en la organización, produciendo daños materiales o pérdidas inmateriales

**12. El riesgo se puede:**

- a) Eliminar, reducir, asumir o transferir.
- b) Eliminar, reducir pero no asegurar.
- c) Reducir, asumir, transferir pero nunca se puede eliminar del todo.
- d) Eliminar, reducir, asumir, transferir o asegurar.

**13. ¿Qué dos activos de entre los siguientes considera esenciales MAGERIT versión 3.0 en su Catálogo de Elementos?:**

- a) Equipos y comunicaciones.
- b) Software y hardware.
- c) Tangibles e intangibles.
- d) Información y servicios.

**14. La norma ISO 27002 recoge:**

- a) Buenas prácticas para la gestión de la seguridad de la información.
- b) La reglamentación de interconexión segura de redes inalámbricas (WIFI).
- c) Normativa aplicable para el desarrollo de aplicaciones militares.
- d) Estándares de desarrollo de aplicaciones de uso dual (civil y militar).

**15. Los criterios comunes (criterios de evaluación unificados para la seguridad de los productos IT) se corresponden con la norma:**

- a) ISO 15408
- b) ANSI 14508
- c) CEN 15408
- d) IEEE 14508

**16. ¿Qué es una estructura de desglose de riesgos (RBS)?**

- a) Una representación jerárquica de los riesgos según sus categorías.
- b) Una matriz que vincula la probabilidad de ocurrencia de cada riesgo con su impacto.
- c) Un diagrama de influencias.
- d) Un diagrama de Ishikawa.

**17. ¿Cómo define la Norma UNE ISO IEC 27002 la seguridad de la información?**

- a) La preservación de la confidencialidad y la integridad
- b) La preservación de la confidencialidad, la integridad y la disponibilidad
- c) La obtención de la autenticación y la preservación de la confidencialidad, la integridad y la disponibilidad
- d) La obtención de la autenticación y el no repudio y la preservación de la confidencialidad, la integridad y la disponibilidad

**18. En las organizaciones basadas en la información es crítico que implanten un plan de continuidad y contingencia de negocio. En este contexto, se entiende como Recovery Point Objective (RPO):**

- a) La cantidad máxima de tiempo tolerable que se necesita para verificar el sistema y / o la integridad de los datos
- b) Es el período de tiempo máximo que la organización considera tolerable, durante el que los datos están en riesgo de pérdida.
- c) El tiempo durante el cual una organización pueda tolerar la falta de funcionamiento de sus aplicaciones y la caída de nivel de servicio asociada, sin afectar a la continuidad del negocio.
- d) -

**19. En que norma de carácter internacional basa su terminología Magerit V3**

- a) ISO 14971
- b) ISO 31000
- c) ISO 17799
- d) ISO 90003

**20. Los cuatro pasos del Ciclo de Deming son:**

- a) Planificar, Medir, Monitorizar, Informar
- b) Planificar, Revisar, Reaccionar, Implementar
- c) Planificar, Hacer, Actuar, Auditar
- d) Planificar, Hacer, Revisar, Actuar

**21. Indica cuál de las siguientes afirmaciones es CORRECTA:**

- a) Las contramedidas se implementan sin tener en cuenta los riesgos identificados.
- b) La gestión del riesgo se basa exclusivamente en el análisis de los indicadores relativos al número de intrusiones que se han detectado en cada período.
- c) La gestión de riesgos se basa siempre en una escala cuantitativa.
- d) Ninguna de las anteriores.

**22. Una amenaza es, de acuerdo a MAGERIT:**

- a) Daño producido a una organización por un posible incidente
- b) Resultado de una agresión
- c) Evento que puede desencadenar un incidente en la organización, produciendo daños materiales o pérdidas inmateriales
- d) Posibilidad de ocurrencia de un incidente

**23. La norma ISO 27002:**

- a) es un estándar de facto para la prestación de servicios de seguridad de la Tecnología de la Información.
- b) tiene como objetivo proporcionar una base común para la gestión de la seguridad dentro de las organizaciones.
- c) establece 36 dominios de control para la gestión de la seguridad.
- d) establece un sistema de certificación adecuado a la norma.

**24. El análisis de las necesidades de la organización, la implantación y ejecución de controles y medidas para gestionar la capacidad de la organización frente a incidentes, la supervisión y revisión del rendimiento y la mejora continua son los pilares de:**

- a) La planificación de sistemas.
- b) La gestión de la configuración.
- c) La gestión de cambios.
- d) La gestión de la continuidad del negocio.

**25. La técnica de MAGERIT v3 que se utiliza para modelar las diferentes formas de alcanzar un objetivo se denomina:**

- a) Análisis logarítmico.
- b) Árboles de ataque.
- c) Valoración Delphi.
- d) Gráficos de radar.

**26. La herramienta PILAR sirve para:**

- a) Proporcionar una defensa preventiva frente a ataques de tipo ransomware mediante el despliegue de vacunas.
- b) Realizar el análisis de riesgos según la metodología ISO 9001.
- c) Realizar el análisis de coste/beneficio según la metodología APR.
- d) Realizar el análisis de riesgos según la metodología Magerit e ISO/IEC 27005.

**27. ¿A qué se denomina riesgo en MAGERIT versión 3?**

- a) Estimación del grado de exposición a que una amenaza se materialice sobre uno o más activos causando daños o perjuicios a la Organización.
- b) Al suceso que puede afectar a un activo y causarle un daño.
- c) A la medida del daño sobre un activo derivado de la materialización de una amenaza.
- d) Al recurso del sistema de información expuesto a un ataque.

**28. ¿Cuál de los siguientes conceptos NO es un elemento básico de MAGERIT?**

- a) activo
- b) salvaguarda
- c) amenaza
- d) vulnerabilidad

**29. Según MAGERIT 3.0, el informe en el que se recogen los resultados de la identificación de las amenazas relevantes sobre el sistema a analizar, caracterizadas por las estimaciones de ocurrencia y daño causado, se denomina:**

- a) Estimación del riesgo.
- b) Plan de salvaguardas.
- c) Declaración de aplicabilidad.
- d) Mapa de riesgos.

**30. La evaluación del riesgo es:**

- a) subjetiva
- b) objetiva
- c) Matemática
- d) Estadística

**31. Indique cuál es la norma española en base a la cual se certifica un Sistema de Gestión de la Seguridad de la Información:**

- a) ISO/IEC TR 13335
- b) UNE 71501 IN
- c) UNE-ISO/IEC 17799
- d) UNE-ISO/IEC 27001

**32. Dentro del conjunto de normas de la familia ISO 27000, ¿cual de las siguientes afirmaciones es la INCORRECTA?**

- a) ISO/IEC 270001 define los requisitos a cumplir para implantar un Sistema de Gestión de Seguridad de Información certificable conforme a la norma 27000.
- b) ISO/IEC 270002 se usa para crear la estructura de la seguridad de la información en la organización e ISO/IEC 270001 define controles de manera mucho más detallada.
- c) ISO/IEC 270002 define buenas prácticas para la Gestión de la Seguridad de los sistemas de información de una organización.
- d) ISO/IEC 270001 sigue un modelo PDCA (Plan-Do-Check-Act).

**33. Los mecanismos de salvaguarda, de acuerdo a MAGERIT son:**

- a) Un dispositivo lógico que reduce el riesgo
- b) Un dispositivo físico que reduce el riesgo
- c) Aquellos que operan de forma preventiva sobre la vulnerabilidad
- d) Todas las respuestas anteriores son correctas

**34. El punto objetivo de recuperación que marcará la frecuencia de copias de respaldo:**

- a) RTPO
- b) RTO
- c) DRP
- d) RPO

**35. La probabilidad de explosión por escape de gas en una fábrica es de 0'0001. Si llega a producirse se sabe que morirán al menos diez empleados y se producirán pérdidas materiales por al menos de 100 millones de euros. ¿Cuál es riesgo cuantitativo asociado a la amenaza de explosión?**

- a) 10000 euros
- b) 100 millones de euros
- c) No se puede valorar porque la pérdida de vidas humanas no es cuantificable (salvo para las compañías de seguros)
- d) Muy alto

**36. ¿Con qué ámbito se relaciona COSO?**

- a) Con control de la calidad, es similar al EFQM
- b) Con el marco de Seguridad de las Tecnologías de la Información, similar a la ISO 27000
- c) Con el Análisis y Gestión de Riesgos generales de una organización
- d) Con el control de los servicios de Tecnologías de la Información, similar a ITIL

**37. En el ámbito de las Tecnologías de la Información, señale de entre las siguientes, cuál se considera una amenaza según Magerit v3:**

- a) Ataques en Cascada.
- b) Formación del Personal.
- c) Ingeniería Social.
- d) Inspecciones de Seguridad.

**38. En cuanto a la gestión de incidencias según ISO 27001, ¿qué afirmación es FALSA?**

- a) El trabajo de gestión de una incidencia se termina una vez que la incidencia se ha resuelto o mitigado
- b) El proceso de gestión de una incidencia da comienzo con la notificación de la misma por parte de la persona que la detecta.
- c) Una vez detectado el incidente, se debe proceder a su clasificación.
- d) Una vez el incidente se ha resuelto, se informará sobre su cierre a la persona que lo ha notificado

**39. ¿Cual es la función principal del conjunto de herramientas 'PILAR' desarrollado por el CCN- CERT?**

- a) Gestión de Ciberincidentes en las entidades del ámbito de aplicación del Esquema Nacional de Seguridad.
- b) Almacenamiento virtual de información (archivos, muestras, aplicaciones, etc.).
- c) Análisis y gestión de riesgos de un sistema de información.
- d) Auditoría de cumplimiento con el Esquema Nacional de Interoperabilidad.

**40. La Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información, MAGERIT, establece unas dimensiones canónicas de valoración de activos. Determine cuál de las siguientes respuestas es correcta:**

- a) Disponibilidad, integridad de los datos y confidencialidad de los datos.
- b) Disponibilidad, integridad de los datos, confidencialidad de los datos, eficacia y eficiencia.
- c) Eficacia, eficiencia, disponibilidad, integridad, confidencialidad, conformidad y fiabilidad.
- d) Disponibilidad, integridad de los datos, confidencialidad de los datos, autenticidad de los usuarios del servicio, autenticidad del origen de los datos, trazabilidad del servicio, trazabilidad de los datos.

**41. En la metodología MAGERIT la definición «eventos que pueden desencadenar un incidente en la organización» corresponde a:**

- a) Riesgo
- b) Impacto
- c) Amenaza
- d) Vulnerabilidad

**42. ¿Cuál de los siguientes es un objetivo de la gestión de riesgos?**

- a) Aumentar el presupuesto de seguridad de Tecnologías de la Información
- b) Transparencia hacia la empresa de los riesgos significativos
- c) Conocimiento de las últimas herramientas en materia de seguridad
- d) Conducir un análisis de riesgo detallado

43. Si se estima en un 20% la probabilidad de un incidente que provoca una pérdida de 10.000 euros, se está hablando de:
- a) Un riesgo
  - b) Un impacto
  - c) Ninguna de las anteriores
  - d) a) y b)
44. ¿Cuál de las siguientes satisface una autenticación de usuario de dos factores?
- a) Escaneo de iris y de huella dactilar
  - b) Identificador de usuario y sistema GPS
  - c) Smartcard que requiere un código PIN
  - d) Identificador de usuario más contraseña
45. Seleccione la respuesta verdadera sobre los términos empleados para definir la estrategia de continuidad y recuperación en un sistema de información:
- a) El objetivo de Punto de recuperación RPO determina la pérdida aceptable de datos en caso de interrupción.
  - b) El objetivo de Tiempo de Recuperación RTO es el tiempo máximo que el sistema puede estar interrumpido.
  - c) Cuanto más bajo es el RTO más baja es la tolerancia al desastre y más elevado será el coste de las estrategias de recuperación.
  - d) Todas las anteriores son verdaderas.
46. Según MAGERIT v3 los elementos del análisis de riesgos son:
- a) Impacto, riesgos calculados y riesgos intrínsecos.
  - b) Activos, amenazas y salvaguardas.
  - c) Vulnerabilidades, riesgos e impacto.
  - d) Entorno, sistema de información, información, funciones y otros.
47. Cual es la función principal del conjunto de herramientas «PILAR» desarrollado por el CCN-CERT:
- a) Gestión de Ciberincidentes en las entidades del ámbito de aplicación del ENS
  - b) Almacenamiento virtual de información (archivos, muestras, aplicaciones, etc.)
  - c) Análisis y gestión de riesgos de un sistema de información
  - d) Auditoría de cumplimiento con el ENI
48. Según MAGERIT v3, ¿quiénes son participantes en la tarea PS.2 (Plan de ejecución) para llevar a cabo un Plan de Seguridad?
- a) El equipo de proyecto, especialistas en seguridad y especialistas en áreas específicas de seguridad.
  - b) Departamento de desarrollo y departamento de compras.
  - c) El equipo de proyecto y personal especializado en la salvaguarda en cuestión.
  - d) El director de proyecto y el comité de seguimiento.
49. Señale cuál de las siguientes herramientas utilizadas en informática forense es software propietario:
- a) The Sleuth Kit
  - b) Oxygen Forensic Suite
  - c) Volatility
  - d) Santoku

**50. Un honeypot es:**

- a) Un ataque sofisticado de phishing.
- b) Un ransomware bancario.
- c) Un tipo de malware que explota vulnerabilidades 0day.
- d) Un sistema hardware o herramientas software que simulan ser equipos vulnerables para poder exponerlos sin ningún riesgo y permitir el análisis de todos los ataques efectuados sobre ellos.

**51. ¿Qué norma corresponde a «Tecnología de la Información. Técnicas de seguridad. Código de prácticas para los controles de seguridad de la información»?**

- a) UNE ISO/IEC 20000-1.
- b) UNE-EN ISO 9001:2008.
- c) ISO 14001.
- d) UNE-EN ISO/IEC 27002:2017.

**52. Algunos de los elementos tecnológicos que intervienen en la seguridad perimetral corporativa son:**

- a) En la seguridad perimetral corporativa sólo intervienen enrutadores y switches.
- b) Switches, servidores y aplicaciones departamentales.
- c) Enrutadores, cortafuegos y sistemas VPN.
- d) Servidores, tecnologías inalámbricas, sistemas de usuarios y aplicaciones departamentales.

**53. ¿En qué se diferencia el Plan de Continuidad de Negocio y el Plan de Recuperación ante Desastres?**

- a) No existe ninguna diferencia, son términos equivalentes.
- b) El Plan de Continuidad de Negocio se centra en la parte reactiva de las TIC mientras que el de Recuperación ante Desastres afecta a todos los departamentos de la organización.
- c) El Plan de Recuperación ante Desastres se centra en la parte reactiva y es un subconjunto del Plan de Continuidad de Negocio.
- d) Ninguna de las anteriores.

**54. ¿Qué norma corresponde a «Tecnología de la Información. Técnicas de seguridad. Código de prácticas para los controles de seguridad de la información»?**

- a) UNE-EN ISO/IEC 27002:2017
- b) UNE ISO/IEC 20000-1
- c) UNE-EN ISO 9001:2008
- d) ISO 14001

**55. La autenticación fuerte requiere dos de los tres atributos de autenticación, de entre los que se encuentran:**

- a) Algo que alguien sabe
- b) Algo que alguien tiene
- c) A y B son correctas
- d) A y B son incorrectas

**56. El dominio de control «Seguridad ligada al personal» se corresponde con la dimensión de seguridad:**

- a) Organizativa.
- b) Lógica.
- c) Física.
- d) Legal.



**57. Documento que indica por escrito como una organización planea proteger los recursos físicos e informáticos:**

- a) Acuerdo de Licencia de Usuario Final (EULA)
- b) Política de Seguridad
- c) Acuerdo de nivel de servicio (SLA)
- d) Gestión de relaciones entre socios (PRM)

**58. Indicar cuál de los siguientes NO está entre los objetivos que persigue MAGERIT v3:**

- a) Ofrecer un método sistemático para analizar los riesgos derivados del uso de tecnologías de la información y comunicaciones (TIC).
- b) Ayudar a descubrir y planificar el tratamiento oportuno para mantener los riesgos bajo control.
- c) Establecer una norma de obligado cumplimiento para todos los organismos de las Administraciones Públicas españolas a la hora de analizar y gestionar los riesgos.
- d) Preparar a la Organización para procesos de evaluación, auditoría, certificación o acreditación, según corresponda en cada caso.

**59. Según la Norma UNE-ISO/IEC 27001:2017, la facultad de un control para lograr los objetivos de seguridad para la que fue diseñado se denomina:**

- a) eficacia de un control
- b) eficiencia de un control
- c) idoneidad de un control
- d) finalidad de un control

**60. ¿Cuál de los siguientes pasos será el último en un Proceso de Gestión de Riesgos, según se establece en la Guía de Seguridad de las TIC CCN-STIC 801?**

- a) Implementar las medidas de seguridad.
- b) Obtener la autorización para operar.
- c) Monitorizar.
- d) Evaluar la seguridad del sistema de información.

**61. Indique cuál de las siguientes afirmaciones NO es correcta en relación a MAGERIT:**

- a) En MAGERIT 3, vulnerabilidad de un activo es la potencialidad o posibilidad de ocurrencia de la materialización de una amenaza sobre dicho activo
- b) Se permite estructurar el conjunto de activos en capas
- c) Se consideran activos esenciales, la información que se maneja y los servicios prestados
- d) Define que los activos están expuestos a amenazas que interesan por su valor

**62. En la metodología MAGERIT, se define vulnerabilidad como:**

- a) El daño producido a la organización por un posible incidente
- b) La posibilidad de que se produzca un impacto dado en la organización
- c) Cualquier activo del sistema
- d) Defecto o debilidad en el diseño, implementación u operación de un sistema que habilita o facilita la materialización de una amenaza

**63. Para desarrollar un plan de continuidad de negocio de éxito es fundamental la participación del usuario final durante el proceso de:**

- a) Estrategias de recuperación
- b) Desarrollo del plan detallado
- c) Análisis de impacto al negocio (BIA)
- d) Mantenimiento y pruebas

**64. La norma ISO/IEC 27001:2022:**

- a) Es un estándar comúnmente aceptado para la gestión de riesgos de seguridad de la información.
- b) Disponer de una certificación bajo esta norma ISO supone el cumplimiento del Esquema Nacional de Seguridad, ya que existe una equivalencia entre ambos estándares formalmente reconocida en el RD 311/2022 por el que se regula el Esquema Nacional de Seguridad.
- c) No es certificable.
- d) Es un estándar comúnmente aceptado para la implantación de sistemas de gestión de seguridad de la información, o ISMS - information security management systems por sus siglas en inglés.

**65. ¿Cuál de las siguientes es una norma certificable?**

- a) ISO/IEC 27003
- b) UNE-ISO/IEC 27002:2009
- c) UNE-ISO/IEC 27001:2017
- d) BS 7799-1

**66. Según MAGERIT V3, la relación de amenazas a las que están expuestas los activos se llama:**

- a) Modelo de amenazas.
- b) Informe de suficiencias.
- c) Mapa de riesgos.
- d) Listado de vulnerabilidades.

**67. La versión actual de la metodología de análisis y gestión de riesgos MAGERIT es:**

- a) 1
- b) 2
- c) 3
- d) 4

**68. Señale cuál de las siguientes versiones de PILAR es una versión reducida, destinada a la realización de análisis de riesgos muy rápidos:**

- a) PILAR Basic
- b) PILAR Mini
- c) .PILAR
- d) RMAT

**69. Magerit es una herramienta de:**

- a) Gestión de tiempos de proyectos
- b) Gestión de recursos
- c) Gestión operativa
- d) Gestión de riesgos

**70. Según MAGERIT v3, el informe en el que se recogen los resultados de la identificación de las amenazas relevantes sobre el sistema a analizar, caracterizadas por las estimaciones de ocurrencia y daño causado, se denomina:**

- a) Estimación del riesgo
- b) Evaluación de salvaguardas
- c) Declaración de aplicabilidad
- d) Mapa de riesgos

**71. Según la Norma UNE-ISO/IEC 27002:2017 cuál de los siguientes aspectos NO está incluido en el control de accesos:**

- a) seguridad de los servicios de red
- b) sincronización de relojes
- c) responsabilidades del usuario
- d) control de acceso a la librería de programa as fuente

**72. Según Magerit v3 cuál de las siguientes tareas NO forma parte de la actividad de caracterización de los activos en el Análisis de Riesgos:**

- a) Identificación de los activos.
- b) Dependencias entre activos.
- c) Auditoría de los activos.
- d) Valoración de los activos.

**73. El tiempo máximo en el que se debe alcanzar un nivel de servicio mínimo tras una caída del servicio sin afectar a la continuidad de negocio se denomina:**

- a) RPO (Recovery Point Objective).
- b) MRT (Maximum Recovery Time).
- c) RTO (Recovery Time Objective).
- d) MTD (Maximum Tolerable Downtime).

**74. ¿Cuál es el nombre con que se conoce en MAGERIT versión 3 a la persona de la organización, con buen conocimiento de personas y unidades implicadas en el proyecto de Análisis de Gestión de Riesgos, que tiene la capacidad para conectar al equipo de proyecto con el grupo de usuarios?**

- a) Promotor
- b) Enlace operacional
- c) Director de proyecto
- d) Responsable de servicios internos

**75. El período de tiempo tras un incidente dentro del cual se reanuda un producto, servicio o actividad o se recuperan recursos, se denomina:**

- a) Análisis de impacto al negocio (BIA).
- b) Periodo máximo tolerable de interrupción (MTPD).
- c) Objetivo de punto de recuperación (RPO).
- d) Objetivo de tiempo de recuperación (RTO).

**76. La seguridad física de los sistemas de información:**

- a) Debido a la segregación de tareas, es labor exclusiva de los guardias de seguridad
- b) Debe alcanzar también a los equipos que estén fuera de los locales de la Organización (equipos en teletrabajo, dispositivos móviles, etc.)
- c) Es una preocupación que se evita al externalizar las funciones de explotación del sistema de información
- d) Es notablemente superior en aquellas Organizaciones que disponen de sótanos bunkerizados

**77. Indique la respuesta correcta: la metodología de análisis de gestión de riesgos «MAGERIT»...**

- a) No necesita de la intervención de los responsables de los sistemas de información.
- b) Está desarrollada por Computer Emergency Response Team (CERT).
- c) Fue creada por el Consejo Superior de Administración Electrónica.
- d) Sigue la terminología de la norma ISO 41000.

**78. Para determinar el nivel aceptable de seguridad hay que llegar a un equilibrio entre:**

- a) El coste de los daños versus el coste de sus consecuencias
- b) El coste de las medidas de seguridad versus el presupuesto disponible
- c) Los costes y la probabilidad de los daños versus el coste de las medidas y seguridad para evitarlos
- d) El coste de los daños versus los daños que somos capaces de aceptar

**79. En MAGERIT, el riesgo residual es ...**

- a) el riesgo aceptado
- b) el riesgo despreciable
- c) el riesgo recomendable.
- d) el riesgo que resultaría tras aplicar un conjunto determinado de controles

**80. El primer paso a la hora de desarrollar un Plan de Continuidad de Negocio es:**

- a) Clasificar los sistemas según su importancia
- b) Establecer una estrategia de recuperación de desastres
- c) Determinar el tiempo crítico de recuperación
- d) Realizar una clasificación del riesgo

**81. En el ámbito de la disponibilidad de la información ¿qué es el RPO?**

- a) Es la cantidad máxima de información que puede perderse cuando el servicio es restaurado tras una interrupción del sistema.
- b) Es la cantidad máxima de tiempo tolerable necesario para que todos los sistemas críticos vuelvan a estar en línea.
- c) Es la cantidad máxima de tiempo tolerable que se necesita para verificar el sistema y/o la integridad de los datos.
- d) Es la cantidad total de tiempo que un proceso de negocio puede interrumpirse sin causar consecuencias inaceptables.

**82. MAGERIT:**

- a) Es una metodología de análisis de riesgos
- b) Es una metodología de gestión de riesgos
- c) Es una metodología de gestión de proyectos
- d) Las respuestas 'a' y 'b' son correctas

**83. En la metodología MAGERIT, el evento que pueden desencadenar un incidente en la organización, produciendo daños materiales o pérdidas inmateriales en sus activos, se denomina:**

- a) Impacto
- b) Vulnerabilidad
- c) Amenaza
- d) Riesgo

**84. Las medidas de seguridad necesarias para restaurar el servicio de forma rápida, eficiente y con el menor costo y pérdidas posibles se incluyen en:**

- a) Plan de Recuperación de Desastres
- b) Plan estratégico
- c) Plan de sistemas
- d) Plan de seguridad física

**85. En MAGERIT ¿cuál de las siguientes opciones NO es cierta?**

- a) Riesgo es la posibilidad de que suceda un daño o perjuicio
- b) Impacto es el evento que puede desencadenar un incidente en la organización
- c) Existen tres submodelos: elementos, eventos y procesos
- d) La información es un activo

**86. Las dimensiones canónicas de la seguridad son:**

- a) Disponibilidad, confidencialidad y trazabilidad
- b) Confidencialidad, autenticidad y disponibilidad
- c) Integridad, trazabilidad y autenticidad
- d) Confidencialidad, integridad y disponibilidad

**87. Un centro alternativo de tratamiento de la información:**

- a) Debe ser identificable desde el exterior, para que sea fácilmente localizado en caso de emergencia.
- b) Debe tener las mismas restricciones de acceso físico que la instalación principal.
- c) Debe estar ubicado en las proximidades de la instalación principal, así se puede poner en operación inmediatamente.
- d) No necesita disponer del mismo nivel de supervisión ni controles ambientales que la instalación principal, porque los costes serían prohibitivos.

**88. Un evento con consecuencias en detrimento de la seguridad del sistema de información se denomina, según MAGERIT v.3:**

- a) Incidente
- b) Incidencia
- c) Contingencia
- d) Impacto

**89. En MAGERIT, el riesgo residual es...**

- a) el riesgo aceptado.
- b) el riesgo despreciable.
- c) el riesgo recomendable.
- d) el riesgo que resultaría tras aplicar un conjunto determinado de controles.

**90. Atendiendo al estándar ISO 22301 en un Plan de Recuperación ante Desastres, el Objetivo de Punto de Recuperación (Recovery Point Objective RPO) es:**

- a) el nivel de servicios a proporcionar en modo alterno hasta que se recupere la situación normal.
- b) el tiempo que la organización puede soportar desde que se produce el fallo hasta que se recuperan los servicios críticos.
- c) el tiempo máximo tolerable de interrupción.
- d) la pérdida máxima de datos tolerable en caso de interrupción.

**91. La política de seguridad de alto nivel de la Organización:**

- a) Debe describir QUE se intenta proteger, POR QUE se debe hacer, sin entrar en detalles acerca del COMO.
- b) Debe describir QUE se intenta proteger, POR QUE se debe hacer y COMO se debe implementar.
- c) Debe describir QUE se intenta proteger, POR QUE se debe hacer, COMO se debe implementar y CUANDO hay que implementar los mecanismos de seguridad.
- d) Debe describir QUE se intenta proteger, COMO se debe implementar y CUANDO hay que implementar los mecanismos de seguridad.

**92. En cuanto a la dependencia entre activos, a la hora de evaluar riesgos:**

- a) La seguridad del activo superior depende de la del inferior.
- b) El activo superior puede ser atacado a través del inferior.
- c) La relación indica que el activo inferior es necesario para que el superior funcione.
- d) La a) y la b) son correctas.

**93. Según MAGERIT v3, en el desarrollo de sistemas de información:**

- a) La seguridad debe estar embebida en el sistema desde su primera concepción.
- b) La seguridad comenzará a considerarse formalmente cuando finalice el proceso de implantación de sistemas de información.
- c) La seguridad del sistema de información es más económica implantarla una vez puesto en producción el sistema de información que tenerla en consideración durante el desarrollo del sistema.
- d) La seguridad sólo ralentiza el proceso de desarrollo de sistemas de información por lo que sólo se debe considerar en aquellos sistemas que usen datos económicos.

**94.Cuál de las siguientes es una norma internacional emitida por la Organización Internacional de Normalización (ISO) que describe cómo gestionar la seguridad de la información en una organización. Es certificable.**

- a) ISO 27000
- b) ISO 27001
- c) ISO 27002
- d) ISO 33000

**95. El impacto es, de acuerdo a MAGERIT:**

- a) Daño sobre el activo derivado de la materialización de la amenaza
- b) Lo que podría pasar
- c) Las respuestas 'a' y 'b' son correctas
- d) Lo que probablemente pase

**96. El contenido de la norma ISO 27001 se divide en secciones, ¿cuál de las siguientes NO se corresponde con una sección de la misma?**

- a) Mejora del SGSI.
- b) Auditorías internas.
- c) Responsabilidad de la dirección.
- d) Plan de seguridad.

**97. El RPO (Recovery Point Objective) de una organización son 2 horas. ¿Cuál de las siguientes afirmaciones es cierta?**

- a) No más de 2 horas de datos de producción se pueden perder en caso de desastre.
- b) No más de 4 horas de datos de producción se pueden perder en caso de desastre.
- c) El tiempo para recuperar los sistemas en producción de nuevo no puede ser más de 2 horas.
- d) El tiempo para recuperar los sistemas en producción de nuevo no puede ser más de 4 horas.

**98. Según la norma ISO/IEC 27002:2022, ¿qué política debe aplicarse en los puestos de trabajo para minimizar el riesgo de acceso no autorizado a la información cuando el usuario se ausenta?**

- a) Política de uso aceptable (Acceptable Use Policy)
- b) Política de copias de seguridad locales (Local Backup Policy)
- c) Política de escritorio y pantalla limpios (Clear Desk & Clear Screen)
- d) -

**99. Según MAGERIT versión 3 en un proyecto de análisis de gestión de riesgos, qué producto de salida de los citados a continuación NO se genera en la tarea de Planificación del proyecto:**

- a) Relación de participantes en los grupos de interlocutores.
- b) Plan de entrevistas.
- c) Informe de recursos necesarios.
- d) Especificación detallada de los objetivos del proyecto.

**100. Señale de las siguientes cuál es una técnica específica dentro de un proyecto de análisis y gestión de riesgos, según la guía de Técnicas de MAGERIT v3:**

- a) Sesiones de trabajo.
- b) Valoraciones Delphi.
- c) Histogramas.
- d) Árboles de ataque.

**101. ¿Cuál de los siguientes no se considera un riesgo de origen accidental?**

- a) Huelga del personal
- b) Errores en la utilización de los datos
- c) Averías en las instalaciones eléctricas
- d) Interrupción de suministro de energía

**102. Según la Norma UNE-ISO/IEC 27001:2017, la facultad de un control para lograr los objetivos de seguridad para la que fue diseñado se denomina:**

- a) Eficiencia de un control
- b) Finalidad de un control
- c) Idoneidad de un control
- d) Eficacia de un control

**103. Qué norma UNE se ocupa de los sistemas de gestión de la seguridad de la información**

- a) UNE-ISO/IEC 20000-1:2018
- b) UNE-ISO/IEC 27001:2017
- c) UNE-ISO/IEC 19770-1:2008
- d) -

**104. Tras la realización de un análisis de riesgos de acuerdo con MAGERIT 3.0, el informe que detalla los activos, sus dependencias, las dimensiones en que son valiosos y la estimación de dicho valor, se denomina:**

- a) modelo de valor.
- b) declaración de aplicabilidad.
- c) mapa de riesgos.
- d) estado de riesgo.

**105. Acorde a MAGERIT v3, una vez identificado y valorado el riesgo residual actual, se procede a su tratamiento. ¿Cuál NO es una estrategia de tratamiento del riesgo?**

- a) Mitigar.
- b) Asumir.
- c) Compartir/transferir.
- d) Todas son estrategias de tratamiento del riesgo.

**106. ISACA:**

- a) Es la Information Security Audit and Control Association
- b) Posee una metodología basada en COBIT, de cara a obtener los controles a aplicar durante la auditoría y en CMMI, de cara a obtener un modelo de desarrollo sobre el que basarse para auditar el existente
- c) Posee una metodología propia, que no se basa ni en COBIT ni en CMMI
- d) Ninguna de las anteriores

**107. Respecto a la metodología MAGERIT y la gestión de riesgos, el riesgo calculado, tomando en consideración el valor propio de un activo y el valor de los activos que dependen de él, se denomina:**

- a) Riesgo inherente.
- b) Riesgo repercutido
- c) Riesgo acumulado.
- d) Riesgo total.

**108. ¿Cuál de las siguientes situaciones NO puede considerarse un incidente?**

- a) Fallo hardware.
- b) Un uso no autorizado de la cuenta de un usuario.
- c) Un evento cuyo impacto no genere una interrupción prolongada del servicio.
- d) Todos los anteriores se considerarían incidentes.

**109. ¿Cuál de las siguientes es una amenaza que afecta a la integridad de la información?**

- a) Fugas de información: de forma no intencionada, la información acaba en manos de quién no debe poseerla.
- b) Revelación intencionada de información: un usuario interno de la organización por diversas motivaciones (venganza, convicciones morales, políticas, etc.) decide revelar información de la que tiene acceso.
- c) Ransomware o criptoataque: un malware ataca nuestro sistema cifrando los archivos de modo que están irrecuperables salvo que se halle la clave para su descifrado.
- d) Ingeniería social: un atacante utiliza tretas para sonsacar información de los usuarios que tienen acceso a la misma.

**110. ¿Cuál es la herramienta del CCN para la gobernanza de la ciberseguridad, que permite evaluar regularmente el estado de la seguridad de los sistemas TIC de las entidades, organismos y organizaciones?**

- a) ATENEA.
- b) CLARA.
- c) INES.
- d) CARLA.

**111. ¿Cuál es una de las dimensiones de seguridad de la información?**

- a) Aislamiento.
- b) Consistencia.
- c) Disponibilidad.
- d) Autenticación.

**112. A la máxima cantidad de datos que se pueden perder en caso de desastres se le denomina:**

- a) RTO
- b) RPO
- c) SDO
- d) RDO



**113. ¿Cómo se denomina la metodología de análisis y gestión de riesgos elaborada por el antiguo Consejo Superior de Administración Electrónica (actualmente Comisión de Estrategia TIC)?**

- a) MAGERIT
- b) Pilar
- c) COBIT
- d) ISO 31000

**114. Indique la respuesta INCORRECTA:**

- a) Las herramientas PILAR soportan el análisis y la gestión de riesgos de un sistema de información siguiendo la metodología MAGERIT.
- b) El acrónimo PILAR significa: Procedimiento Integral Lógico para el Análisis de Riesgos.
- c) Las herramientas PILAR disponen de una biblioteca estándar de propósito general.
- d) Las herramientas PILAR son capaces de realizar calificaciones de seguridad respecto a ISO/IEC 27002 (2005, 2013) - Código de buenas prácticas para la Gestión de la Seguridad de la Información -.

**115. Ignorar quien accede a que dato y cuando lo hace, afecta a la dimensión de la seguridad denominada:**

- a) confidencialidad
- b) disponibilidad
- c) integridad
- d) trazabilidad

**116. Como medidas de tipo físico, en seguridad informática, podemos hablar de:**

- a) Seguridad de datos y de software
- b) Seguridad organizativo-administrativa y de software
- c) Seguridad de hardware y de datos
- d) Adecuación de locales y seguridad de accesos

**117. La serie ISO 27000 contiene las mejores prácticas recomendadas en Seguridad de la información para desarrollar, implementar y mantener Especificaciones para los Sistemas de Gestión de la Seguridad de la Información (SGSI). Respecto a las diferentes normas de esta serie es CIERTO:**

- a) La ISO 27001 es la norma principal de la serie y contiene los requisitos del sistema de gestión de seguridad de la información.
- b) El Anexo A de la ISO 27001 enumera en forma de resumen los objetivos de control y controles que desarrolla. Es obligatoria la implementación de todos los controles enumerados en dicho anexo.
- c) La ISO 27002 es una guía para el desarrollo y utilización de métricas y técnicas de medida aplicables para determinar la eficacia de un SGSI y de los controles o grupos de controles implementados.
- d) La ISO 27003 es la única norma certificable de la serie.

**118. Según MAGERIT v3, ¿qué concepto se correspondería con la definición: «proceso específico cuyo objetivo es legitimar al sistema para formar parte de sistemas más amplios»?**

- a) Auditoría.
- b) Acreditación.
- c) Certificación.
- d) Evaluación.

**119. ¿Cuál de los siguientes libros NO forma parte de MAGERIT v3?**

- a) Método.
- b) Catálogo de elementos.
- c) Catálogo de riesgos.
- d) Guía de Técnicas.

**120. De las siguientes normas, ¿cuál está referida al código de buenas prácticas en gestión de la seguridad de la Información?**

- a) ISO/IEC 13335-2.
- b) ISO/IEC 27002:2022.
- c) UNE 71502:2004.
- d) ISO 10646.

**121. ¿Qué NO debe incluir la implementación de un plan de continuidad de negocio dentro de un Sistema de Gestión de la Seguridad de la Información?**

- a) Designar y formar a las personas que deben intervenir en cada caso
- b) Documentar y construir procedimientos de actuación en cada caso
- c) Aportar una definición del alcance del Sistema de Gestión de la Seguridad de la Información
- d) Establecer una estructura de gestión y sus niveles de competencia dentro del plan de continuidad

**122. Si un equipo tiene una avería ¿cuál de los siguientes indicadores nos da información sobre el tiempo medio requerido para reparar dicha avería?**

- a) MTBF
- b) MTBR
- c) MTTR
- d) MTTF

**123. Entre la documentación de la Seguridad de la Organización nos podremos encontrar:**

- a) La Política de Seguridad Corporativa será elaborada por el Responsable de Seguridad Corporativa y aprobada por el Comité de Seguridad Corporativa y por la Alta Dirección.
- b) La Política de Seguridad de las TIC que debe estar alineada en todo momento con el Mantenimiento de los Sistemas de Información.
- c) El Documento de Seguridad que ha de estar presente en toda documentación de la seguridad de la información.
- d) Todas las respuestas anteriores son correctas.

**124. ¿Cuál es la norma principal de la serie ISO que contiene los requisitos del Sistema de Gestión de Seguridad de la Información?**

- a) No existe una norma ISO, pero el ENS define con detalle todos los conceptos necesarios.
- b) ISO 9004:2018.
- c) ISO 14001:2015.
- d) ISO 27001:2022.

**125. Una de las diferencias entre un Plan de Recuperación ante desastres (PRD o DRP en inglés) y un Plan de Contingencia es que:**

- a) El PRD debe ser realizado antes que el Plan de Contingencia.
- b) El Plan de Contingencia debe ser realizado antes que el PRD.
- c) El Plan de Contingencia realiza acciones para poder continuar con las actividades críticas del negocio aunque sea en modo manual o semi automático mientras que el PRD, en paralelo al Plan de Contingencia, trata de recuperar las aplicaciones y la información dañada para volver a la normalidad.
- d) El PRD realiza acciones para poder continuar con las actividades críticas del negocio aunque sea en modo manual o semi automático mientras que el Plan de Contingencia trata de recuperar las aplicaciones y la información dañada para volver a la normalidad.

**126. Según MAGERIT, el conjunto de programas de seguridad que permite materializar las decisiones de gestión de riesgos es el:**

- a) mapa de riesgos
- b) informe de insuficiencias
- c) cuadro de mando
- d) plan de seguridad

**127. Un plan de contingencia corresponde a:**

- a) Evitar el riesgo de daños
- b) Minimizar los daños producidos
- c) Planificar las situaciones de emergencia
- d) Establecer medidas de recuperación

**128. La capacidad de proporcionar y mantener un nivel aceptable de servicio ante la ocurrencia de fallos y desafíos a la operación normal se conoce como:**

- a) Disponibilidad.
- b) Seguridad.
- c) Resiliencia.
- d) Mantenibilidad.

**129. ¿Cuáles son las dimensiones de seguridad según CobiT?**

- a) Confidencialidad, Disponibilidad, Integridad y Autenticidad.
- b) Confidencialidad, Integridad y Disponibilidad.
- c) Confidencialidad, Integridad, Disponibilidad y Autenticación.
- d) Confidencialidad, Integridad, Disponibilidad e Interoperabilidad.

**130. MAGERIT es:**

- a) Una metodología de Análisis y gestión de riesgos de sistemas de información.
- b) Una metodología de Análisis y gestión de centros de recuperación de desastres de sistemas de información.
- c) Una metodología de Análisis y gestión de sistemas de archivo de sistemas de información.
- d) Una metodología de Análisis y gestión de evaluación de rendimiento de sistemas de información.